

Manual 55 — AI Third-Party, Vendor & Supply-Chain Governance

Controlled publication source — English

Purpose

Establish a practical governance framework for AI providers, hosted models, agents, plugins, connectors, MCP servers, data suppliers, subprocessors and other AI supply-chain dependencies across selection, contracting, onboarding, operation, change, incident response and exit. Legal requirements, contractual obligations, supervisory expectations, voluntary frameworks and community guidance must remain explicitly distinguished.

TP-01 — Provider inventory and materiality

Maintain a complete inventory of providers, services, models, APIs, agents, plugins, data sources, hosting dependencies and fourth parties. Classify by criticality, autonomy, data sensitivity, consequence, concentration risk, substitutability and regulatory exposure.

TP-02 — Pre-contract due diligence

Assess ownership, financial viability, security, privacy, AI governance, incident history, documentation, hosting, subcontractors, continuity and evidence availability before approval.

TP-03 — Security and technical assurance

Evaluate access control, tenant isolation, encryption, vulnerability management, secure development, model/API abuse controls, logging, monitoring, incident response and independent assurance evidence proportionate to risk.

TP-04 — Privacy and data-use restrictions

Document permitted data uses, training/fine-tuning use, retention, deletion, secondary use, cross-border processing, sensitive-data restrictions, subprocessors and deletion/return evidence at exit.

TP-05 — Model, version and change transparency

Require identification of material model/service versions, architecture changes, deprecations, behavior changes, safety-control changes and notification mechanisms sufficient to trigger internal revalidation.

TP-06 — Subprocessors and fourth parties

Identify material fourth parties and dependencies. Establish risk-based visibility, approval, notification, flow-down obligations and exit/continuity controls.

TP-07 — Hosting, residency and transfer architecture

Map hosting regions, data locations, control planes, backups, failover and transfer mechanisms. Validate residency commitments against technical and contractual evidence.

TP-08 — Identity, authorization and delegated action

For agents, plugins, connectors and MCP/tool providers, validate identity, authorization scope, least privilege, delegated authority, transaction limits, revocation and attributable action logging.

TP-09 — AI supply-chain integrity

Assess model provenance, package/dependency integrity, artifacts, images, containers, libraries, model files, adapters, datasets, prompts, plugins and update channels. Require controls against substitution, tampering, poisoning and unauthorized change.

TP-10 — Contractual control and evidence rights

Establish clauses for security, privacy, AI-use restrictions, audit/evidence access, incident notification, material change, subcontractors, continuity, termination, data return/deletion, cooperation and regulatory support where applicable.

TP-11 — Performance and safety claims

Challenge material provider claims regarding accuracy, robustness, safety, fairness, privacy, security, certifications and benchmarks. Distinguish independently verified evidence from supplier assertions.

TP-12 — Change and revalidation

Define reassessment triggers: model/version change, new subprocessor, hosting change, control failure, security incident, data-use change, ownership change, financial distress, benchmark regression or new applicable requirement.

TP-13 — Incident and breach coordination

Define notification windows, evidence-sharing, containment roles, communications, forensic cooperation, regulatory support and corrective actions.

TP-14 — Concentration and systemic dependency risk

Assess single-provider concentration, common cloud/foundation-model dependencies, shared libraries, common data providers, regional concentration and correlated failure scenarios.

TP-15 — Continuity, portability and exit

Validate backup/restore, alternate providers, data/model portability, export formats, migration, credential revocation, data deletion and residual dependency removal.

TP-16 — Ongoing monitoring

Monitor provider risk signals, service changes, advisories, regulatory actions, version changes, SLA degradation, incidents, evidence expirations and unresolved findings.

TP-17 — Exceptions and residual risk

Record approved deviations, rationale, compensating controls, accountable owner, expiration, review triggers and closure evidence.

TP-18 — Post-exit assurance

Confirm access removal, credential revocation, data return/deletion, model or adapter disposal where applicable, subprocessor termination effects, retention exceptions and evidence preservation.

Required evidence

EV-01 inventory/materiality; EV-02 due diligence; EV-03 security/privacy evidence; EV-04 architecture/data flow; EV-05 fourth-party register; EV-06 model/version/change register; EV-07 contract clause matrix; EV-08 provider-claims challenge; EV-09 incident playbook; EV-10 continuity/exit test; EV-11 concentration assessment; EV-12 monitoring log; EV-13 exception record; EV-14 termination/deletion evidence.

Scenario pack

1. Silent hosted-model behavior change.
2. New-region subprocessor.
3. Terms permit customer-data model improvement.
4. Plugin gains permissions.
5. Common dependency compromise.
6. Unsupported safety/security claim.
7. Critical outage without migration path.
8. Coordinated incident containment.
9. Exit with incomplete deletion evidence.
10. Multiple critical services depend on one foundation-model/cloud provider.

Release rule

Supplier claims are not independently verified evidence unless substantiated. Publication remains fail-closed on substantive source, localization, artifact, provenance, visible-text/render and retained QA defects.